

UNIVERSIDAD NACIONAL

Escuela de Informática

Curso: Administración de Bases de Datos (EIF402)

Proyecto Integrador (parte 1)

Aplicación Web para la Evaluación del Riesgo en la Administración de
Bases de Datos Basada en ISO/IEC 27002

Instrumento de Evaluación y Metodologías de Cálculo de Madurez y Riesgo

Integrantes:

Sebastián Garro Granados

Jostin Jiménez Alfaro

Alejandro Calderón Campos

José Castro

Fecha de entrega: 6 de agosto de 2026

1. Introducción

Este documento es la segunda parte del trabajo del equipo y cubre tres entregables del proyecto: el diseño del instrumento de evaluación, la metodología para calcular el nivel de madurez de cada control, y la metodología para calcular la exposición al riesgo de Confidencialidad, Integridad y Disponibilidad, junto con el índice general de riesgo.

Partimos de los 20 controles de la ISO/IEC 27002 que se seleccionaron y justificaron en la primera parte del trabajo, cada uno con su peso y su relación con C, I y D. Esos valores no se tocan en este documento, se usan tal como quedaron definidos anteriormente, porque de ahí sale directamente todo lo que se arma acá: las preguntas del cuestionario y las fórmulas de cálculo de las secciones 4 y 5.

2. Controles Seleccionados en la Primera Parte del Trabajo

En la siguiente tabla se resumen los 20 controles con su dominio, peso y relación con C, I y D, tal como quedaron definidos en la primera parte del trabajo. Se incluyen acá para tenerlos a la mano, porque cada pregunta del cuestionario y cada fórmula de las secciones 4 y 5 se apoyan directamente en estos valores.

Código	Control	Dominio	Peso	C	I	D
5.9	Inventario de activos de información	Organizacional	3	Media	Media	Media
5.12	Clasificación de la información	Organizacional	4	Alta	Media	Baja
5.15	Control de acceso	Organizacional	5	Alta	Alta	Media
5.18	Derechos de acceso	Organizacional	5	Alta	Alta	Media
5.24	Planificación de la gestión de incidentes	Organizacional	3	Media	Media	Alta
5.34	Privacidad y protección de datos personales	Organizacional	4	Alta	Baja	Baja
6.3	Concienciación, educación y capacitación en seguridad	Personas	2	Media	Media	Baja
6.6	Acuerdos de confidencialidad o no divulgación	Personas	3	Alta	Baja	Baja
7.1	Perímetros de seguridad física	Físico	3	Media	Media	Alta
7.10	Medios de almacenamiento	Físico	3	Alta	Media	Media
8.2	Derechos de acceso privilegiado	Tecnológico	5	Alta	Alta	Alta
8.3	Restricción de acceso a la información	Tecnológico	4	Alta	Alta	Media
8.5	Autenticación segura	Tecnológico	4	Alta	Media	Baja
8.8	Gestión de vulnerabilidades técnicas	Tecnológico	4	Alta	Alta	Media
8.9	Gestión de la configuración	Tecnológico	4	Media	Alta	Media
8.13	Copias de seguridad de la información	Tecnológico	5	Baja	Media	Alta
8.15	Registro (logging)	Tecnológico	4	Media	Alta	Media
8.16	Actividades de monitoreo	Tecnológico	4	Media	Alta	Alta
8.24	Uso de criptografía	Tecnológico	4	Alta	Media	Baja
8.32	Gestión de cambios	Tecnológico	3	Media	Alta	Media

3. Diseño del Instrumento de Evaluación

3.1 Enfoque metodológico: preguntas escalonadas ligadas a la escala de madurez

Para diseñar el cuestionario se decidió no dejar un solo ítem por control, sino armar cinco preguntas escalonadas por cada uno, donde cada pregunta corresponde exactamente a uno de los niveles de la escala de madurez 0-5 definida para el proyecto (nivel 1: existe de forma informal; nivel 2: hay documentación parcial; nivel 3: está formalmente implementado; nivel 4: se supervisa con evidencia; nivel 5: se mide y forma parte de mejora continua).

La ventaja de este diseño es que el nivel de madurez deja de depender del criterio del auditor al terminar la entrevista, y se puede calcular de forma automática a partir de las respuestas Sí/No/No aplica. En la sección 4 se explica cómo se hace ese cálculo.

3.2 Reglas de respuesta y registro de evidencia

- Sí: hay evidencia verificable (documento, observación directa o configuración revisada) de que la práctica descrita se cumple.
- No: no hay evidencia de que la práctica descrita se cumple.
- No aplica (N/A): la práctica descrita no le corresponde al contexto tecnológico, contractual u organizativo de la organización auditada, por ejemplo cuando el control se refiere a una tecnología que la organización no usa.
- Cada pregunta tiene además un campo de evidencia/observaciones donde el auditor anota en qué se basó para responder (documento revisado, captura de pantalla, nombre del responsable entrevistado, fecha, etc.), tal como lo pide el alcance funcional del sistema.

Hay un caso particular que conviene aclarar: si la pregunta de nivel 1 de un control se responde No aplica, se entiende que el control completo no aplica a la organización evaluada, y por lo tanto se excluye de todos los cálculos de esa auditoría (cumplimiento, madurez y riesgo), dejando esto documentado en el reporte. En cambio, si la No aplica cae en una pregunta de nivel 2, 3, 4 o 5, solo se excluye esa pregunta puntual del análisis, sin penalizar al control por no tener una práctica que de todas formas no le correspondía implementar. Este punto se retoma con más detalle en la sección 4.1.

3.3 Cuestionario completo

A continuación se presenta el cuestionario completo: 20 controles × 5 preguntas = 100 preguntas, en el mismo orden de dominios y códigos usado en la primera parte del trabajo.

5.9 — Inventario de activos de información

Dominio: Organizacional | Peso: 3/5 | Relación C/I/D: Media / Media / Media

Nivel	Pregunta	Respuesta	Evidencia / observaciones
1	¿Existe alguna práctica, aunque sea informal u ocasional, relacionada con la existencia y actualización del inventario de bases de datos y demás activos de información asociados?	☐ Sí ☐ No ☐ N/A	
2	¿Existen lineamientos o procedimientos documentados sobre la existencia y actualización del inventario de bases de datos y demás activos de información asociados, aunque no se apliquen de manera consistente en todos los casos?	☐ Sí ☐ No ☐ N/A	

Nivel	Pregunta	Respuesta	Evidencia / observaciones
3	¿El procedimiento asociado a la existencia y actualización del inventario de bases de datos y demás activos de información asociados está formalmente definido, documentado e implementado en la mayor parte de las bases de datos y procesos evaluados?	☐ Sí ☐ No ☐ N/A	
4	¿Se supervisa periódicamente el cumplimiento de lo relacionado con la existencia y actualización del inventario de bases de datos y demás activos de información asociados y existe evidencia documentada (bitácoras, reportes o actas) de dicha supervisión?	☐ Sí ☐ No ☐ N/A	
5	¿Se mide el desempeño de la existencia y actualización del inventario de bases de datos y demás activos de información asociados mediante indicadores, se evalúa de forma continua y forma parte de un proceso formal de mejora continua?	☐ Sí ☐ No ☐ N/A	

5.12 — Clasificación de la información

Dominio: Organizacional | Peso: 4/5 | Relación C/I/D: Alta / Media / Baja

Nivel	Pregunta	Respuesta	Evidencia / observaciones
1	¿Existe alguna práctica, aunque sea informal u ocasional, relacionada con la clasificación de la información almacenada en las bases de datos?	☐ Sí ☐ No ☐ N/A	
2	¿Existen lineamientos o procedimientos documentados sobre la clasificación de la información almacenada en las bases de datos, aunque no se apliquen de manera consistente en todos los casos?	☐ Sí ☐ No ☐ N/A	
3	¿El procedimiento asociado a la clasificación de la información almacenada en las bases de datos está formalmente definido, documentado e implementado en la mayor parte de las bases de datos y procesos evaluados?	☐ Sí ☐ No ☐ N/A	
4	¿Se supervisa periódicamente el cumplimiento de lo relacionado con la clasificación de la información almacenada en las bases de datos y existe evidencia documentada (bitácoras, reportes o actas) de dicha supervisión?	☐ Sí ☐ No ☐ N/A	
5	¿Se mide el desempeño de la clasificación de la información almacenada en las bases de datos mediante indicadores, se evalúa de forma continua y forma parte de un proceso formal de mejora continua?	☐ Sí ☐ No ☐ N/A	

5.15 — Control de acceso

Dominio: Organizacional | Peso: 5/5 | Relación C/I/D: Alta / Alta / Media

Nivel	Pregunta	Respuesta	Evidencia / observaciones
1	¿Existe alguna práctica, aunque sea informal u ocasional, relacionada con la aplicación de controles de acceso a las bases de datos?	☐ Sí ☐ No ☐ N/A	
2	¿Existen lineamientos o procedimientos documentados sobre la aplicación de controles de acceso a las bases de datos, aunque no se apliquen de manera consistente en todos los casos?	☐ Sí ☐ No ☐ N/A	

Nivel	Pregunta	Respuesta	Evidencia / observaciones
3	¿El procedimiento asociado a la aplicación de controles de acceso a las bases de datos está formalmente definido, documentado e implementado en la mayor parte de las bases de datos y procesos evaluados?	☐ Sí ☐ No ☐ N/A	
4	¿Se supervisa periódicamente el cumplimiento de lo relacionado con la aplicación de controles de acceso a las bases de datos y existe evidencia documentada (bitácoras, reportes o actas) de dicha supervisión?	☐ Sí ☐ No ☐ N/A	
5	¿Se mide el desempeño de la aplicación de controles de acceso a las bases de datos mediante indicadores, se evalúa de forma continua y forma parte de un proceso formal de mejora continua?	☐ Sí ☐ No ☐ N/A	

5.18 — Derechos de acceso

Dominio: Organizacional | Peso: 5/5 | Relación C/I/D: Alta / Alta / Media

Nivel	Pregunta	Respuesta	Evidencia / observaciones
1	¿Existe alguna práctica, aunque sea informal u ocasional, relacionada con la asignación, revisión y revocación de derechos de acceso sobre las bases de datos?	☐ Sí ☐ No ☐ N/A	
2	¿Existen lineamientos o procedimientos documentados sobre la asignación, revisión y revocación de derechos de acceso sobre las bases de datos, aunque no se apliquen de manera consistente en todos los casos?	☐ Sí ☐ No ☐ N/A	
3	¿El procedimiento asociado a la asignación, revisión y revocación de derechos de acceso sobre las bases de datos está formalmente definido, documentado e implementado en la mayor parte de las bases de datos y procesos evaluados?	☐ Sí ☐ No ☐ N/A	
4	¿Se supervisa periódicamente el cumplimiento de lo relacionado con la asignación, revisión y revocación de derechos de acceso sobre las bases de datos y existe evidencia documentada (bitácoras, reportes o actas) de dicha supervisión?	☐ Sí ☐ No ☐ N/A	
5	¿Se mide el desempeño de la asignación, revisión y revocación de derechos de acceso sobre las bases de datos mediante indicadores, se evalúa de forma continua y forma parte de un proceso formal de mejora continua?	☐ Sí ☐ No ☐ N/A	

5.24 — Planificación de la gestión de incidentes

Dominio: Organizacional | Peso: 3/5 | Relación C/I/D: Media / Media / Alta

Nivel	Pregunta	Respuesta	Evidencia / observaciones
1	¿Existe alguna práctica, aunque sea informal u ocasional, relacionada con la planificación de la respuesta a incidentes de seguridad relacionados con las bases de datos?	☐ Sí ☐ No ☐ N/A	
2	¿Existen lineamientos o procedimientos documentados sobre la planificación de la respuesta a incidentes de seguridad relacionados con las bases de datos, aunque no se apliquen de manera consistente en todos los casos?	☐ Sí ☐ No ☐ N/A	

Nivel	Pregunta	Respuesta	Evidencia / observaciones
3	¿El procedimiento asociado a la planificación de la respuesta a incidentes de seguridad relacionados con las bases de datos está formalmente definido, documentado e implementado en la mayor parte de las bases de datos y procesos evaluados?	☐ Sí ☐ No ☐ N/A	
4	¿Se supervisa periódicamente el cumplimiento de lo relacionado con la planificación de la respuesta a incidentes de seguridad relacionados con las bases de datos y existe evidencia documentada (bitácoras, reportes o actas) de dicha supervisión?	☐ Sí ☐ No ☐ N/A	
5	¿Se mide el desempeño de la planificación de la respuesta a incidentes de seguridad relacionados con las bases de datos mediante indicadores, se evalúa de forma continua y forma parte de un proceso formal de mejora continua?	☐ Sí ☐ No ☐ N/A	

5.34 — Privacidad y protección de datos personales

Dominio: Organizacional | Peso: 4/5 | Relación C/I/D: Alta / Baja / Baja

Nivel	Pregunta	Respuesta	Evidencia / observaciones
1	¿Existe alguna práctica, aunque sea informal u ocasional, relacionada con la protección de los datos personales almacenados en las bases de datos?	☐ Sí ☐ No ☐ N/A	
2	¿Existen lineamientos o procedimientos documentados sobre la protección de los datos personales almacenados en las bases de datos, aunque no se apliquen de manera consistente en todos los casos?	☐ Sí ☐ No ☐ N/A	
3	¿El procedimiento asociado a la protección de los datos personales almacenados en las bases de datos está formalmente definido, documentado e implementado en la mayor parte de las bases de datos y procesos evaluados?	☐ Sí ☐ No ☐ N/A	
4	¿Se supervisa periódicamente el cumplimiento de lo relacionado con la protección de los datos personales almacenados en las bases de datos y existe evidencia documentada (bitácoras, reportes o actas) de dicha supervisión?	☐ Sí ☐ No ☐ N/A	
5	¿Se mide el desempeño de la protección de los datos personales almacenados en las bases de datos mediante indicadores, se evalúa de forma continua y forma parte de un proceso formal de mejora continua?	☐ Sí ☐ No ☐ N/A	

6.3 — Concienciación, educación y capacitación en seguridad

Dominio: Personas | Peso: 2/5 | Relación C/I/D: Media / Media / Baja

Nivel	Pregunta	Respuesta	Evidencia / observaciones
1	¿Existe alguna práctica, aunque sea informal u ocasional, relacionada con la capacitación del personal en seguridad de bases de datos?	☐ Sí ☐ No ☐ N/A	
2	¿Existen lineamientos o procedimientos documentados sobre la capacitación del personal en seguridad de bases de datos, aunque no se apliquen de manera consistente en todos los casos?	☐ Sí ☐ No ☐ N/A	

Nivel	Pregunta	Respuesta	Evidencia / observaciones
3	¿El procedimiento asociado a la capacitación del personal en seguridad de bases de datos está formalmente definido, documentado e implementado en la mayor parte de las bases de datos y procesos evaluados?	☐ Sí ☐ No ☐ N/A	
4	¿Se supervisa periódicamente el cumplimiento de lo relacionado con la capacitación del personal en seguridad de bases de datos y existe evidencia documentada (bitácoras, reportes o actas) de dicha supervisión?	☐ Sí ☐ No ☐ N/A	
5	¿Se mide el desempeño de la capacitación del personal en seguridad de bases de datos mediante indicadores, se evalúa de forma continua y forma parte de un proceso formal de mejora continua?	☐ Sí ☐ No ☐ N/A	

6.6 — Acuerdos de confidencialidad o no divulgación

Dominio: Personas | Peso: 3/5 | Relación C/I/D: Alta / Baja / Baja

Nivel	Pregunta	Respuesta	Evidencia / observaciones
1	¿Existe alguna práctica, aunque sea informal u ocasional, relacionada con los acuerdos de confidencialidad del personal con acceso a las bases de datos?	☐ Sí ☐ No ☐ N/A	
2	¿Existen lineamientos o procedimientos documentados sobre los acuerdos de confidencialidad del personal con acceso a las bases de datos, aunque no se apliquen de manera consistente en todos los casos?	☐ Sí ☐ No ☐ N/A	
3	¿El procedimiento asociado a los acuerdos de confidencialidad del personal con acceso a las bases de datos está formalmente definido, documentado e implementado en la mayor parte de las bases de datos y procesos evaluados?	☐ Sí ☐ No ☐ N/A	
4	¿Se supervisa periódicamente el cumplimiento de lo relacionado con los acuerdos de confidencialidad del personal con acceso a las bases de datos y existe evidencia documentada (bitácoras, reportes o actas) de dicha supervisión?	☐ Sí ☐ No ☐ N/A	
5	¿Se mide el desempeño de los acuerdos de confidencialidad del personal con acceso a las bases de datos mediante indicadores, se evalúa de forma continua y forma parte de un proceso formal de mejora continua?	☐ Sí ☐ No ☐ N/A	

7.1 — Perímetros de seguridad física

Dominio: Físico | Peso: 3/5 | Relación C/I/D: Media / Media / Alta

Nivel	Pregunta	Respuesta	Evidencia / observaciones
1	¿Existe alguna práctica, aunque sea informal u ocasional, relacionada con la seguridad física del centro de datos donde reside el motor de base de datos?	☐ Sí ☐ No ☐ N/A	
2	¿Existen lineamientos o procedimientos documentados sobre la seguridad física del centro de datos donde reside el motor de base	☐ Sí ☐ No ☐ N/A	

Nivel	Pregunta	Respuesta	Evidencia / observaciones
	de datos, aunque no se apliquen de manera consistente en todos los casos?		
3	¿El procedimiento asociado a la seguridad física del centro de datos donde reside el motor de base de datos está formalmente definido, documentado e implementado en la mayor parte de las bases de datos y procesos evaluados?	☐ Sí ☐ No ☐ N/A	
4	¿Se supervisa periódicamente el cumplimiento de lo relacionado con la seguridad física del centro de datos donde reside el motor de base de datos y existe evidencia documentada (bitácoras, reportes o actas) de dicha supervisión?	☐ Sí ☐ No ☐ N/A	
5	¿Se mide el desempeño de la seguridad física del centro de datos donde reside el motor de base de datos mediante indicadores, se evalúa de forma continua y forma parte de un proceso formal de mejora continua?	☐ Sí ☐ No ☐ N/A	

7.10 — Medios de almacenamiento

Dominio: Físico | Peso: 3/5 | Relación C/I/D: Alta / Media / Media

Nivel	Pregunta	Respuesta	Evidencia / observaciones
1	¿Existe alguna práctica, aunque sea informal u ocasional, relacionada con la gestión de los medios de almacenamiento y respaldo de las bases de datos?	☐ Sí ☐ No ☐ N/A	
2	¿Existen lineamientos o procedimientos documentados sobre la gestión de los medios de almacenamiento y respaldo de las bases de datos, aunque no se apliquen de manera consistente en todos los casos?	☐ Sí ☐ No ☐ N/A	
3	¿El procedimiento asociado a la gestión de los medios de almacenamiento y respaldo de las bases de datos está formalmente definido, documentado e implementado en la mayor parte de las bases de datos y procesos evaluados?	☐ Sí ☐ No ☐ N/A	
4	¿Se supervisa periódicamente el cumplimiento de lo relacionado con la gestión de los medios de almacenamiento y respaldo de las bases de datos y existe evidencia documentada (bitácoras, reportes o actas) de dicha supervisión?	☐ Sí ☐ No ☐ N/A	
5	¿Se mide el desempeño de la gestión de los medios de almacenamiento y respaldo de las bases de datos mediante indicadores, se evalúa de forma continua y forma parte de un proceso formal de mejora continua?	☐ Sí ☐ No ☐ N/A	

8.2 — Derechos de acceso privilegiado

Dominio: Tecnológico | Peso: 5/5 | Relación C/I/D: Alta / Alta / Alta

Nivel	Pregunta	Respuesta	Evidencia / observaciones
1	¿Existe alguna práctica, aunque sea informal u ocasional, relacionada con la gestión de cuentas y accesos privilegiados (administrativos) sobre el motor de base de datos?	☐ Sí ☐ No ☐ N/A	

Nivel	Pregunta	Respuesta	Evidencia / observaciones
2	¿Existen lineamientos o procedimientos documentados sobre la gestión de cuentas y accesos privilegiados (administrativos) sobre el motor de base de datos, aunque no se apliquen de manera consistente en todos los casos?	☐ Sí ☐ No ☐ N/A	
3	¿El procedimiento asociado a la gestión de cuentas y accesos privilegiados (administrativos) sobre el motor de base de datos está formalmente definido, documentado e implementado en la mayor parte de las bases de datos y procesos evaluados?	☐ Sí ☐ No ☐ N/A	
4	¿Se supervisa periódicamente el cumplimiento de lo relacionado con la gestión de cuentas y accesos privilegiados (administrativos) sobre el motor de base de datos y existe evidencia documentada (bitácoras, reportes o actas) de dicha supervisión?	☐ Sí ☐ No ☐ N/A	
5	¿Se mide el desempeño de la gestión de cuentas y accesos privilegiados (administrativos) sobre el motor de base de datos mediante indicadores, se evalúa de forma continua y forma parte de un proceso formal de mejora continua?	☐ Sí ☐ No ☐ N/A	

8.3 — Restricción de acceso a la información

Dominio: Tecnológico | Peso: 4/5 | Relación C/I/D: Alta / Alta / Media

Nivel	Pregunta	Respuesta	Evidencia / observaciones
1	¿Existe alguna práctica, aunque sea informal u ocasional, relacionada con la restricción de acceso a nivel de tablas, vistas y procedimientos de la base de datos?	☐ Sí ☐ No ☐ N/A	
2	¿Existen lineamientos o procedimientos documentados sobre la restricción de acceso a nivel de tablas, vistas y procedimientos de la base de datos, aunque no se apliquen de manera consistente en todos los casos?	☐ Sí ☐ No ☐ N/A	
3	¿El procedimiento asociado a la restricción de acceso a nivel de tablas, vistas y procedimientos de la base de datos está formalmente definido, documentado e implementado en la mayor parte de las bases de datos y procesos evaluados?	☐ Sí ☐ No ☐ N/A	
4	¿Se supervisa periódicamente el cumplimiento de lo relacionado con la restricción de acceso a nivel de tablas, vistas y procedimientos de la base de datos y existe evidencia documentada (bitácoras, reportes o actas) de dicha supervisión?	☐ Sí ☐ No ☐ N/A	
5	¿Se mide el desempeño de la restricción de acceso a nivel de tablas, vistas y procedimientos de la base de datos mediante indicadores, se evalúa de forma continua y forma parte de un proceso formal de mejora continua?	☐ Sí ☐ No ☐ N/A	

8.5 — Autenticación segura

Dominio: Tecnológico | Peso: 4/5 | Relación C/I/D: Alta / Media / Baja

Nivel	Pregunta	Respuesta	Evidencia / observaciones
1	¿Existe alguna práctica, aunque sea informal u ocasional, relacionada con los mecanismos de autenticación segura para el acceso a la base de datos?	☐ Sí ☐ No ☐ N/A	
2	¿Existen lineamientos o procedimientos documentados sobre los mecanismos de autenticación segura para el acceso a la base de datos, aunque no se apliquen de manera consistente en todos los casos?	☐ Sí ☐ No ☐ N/A	
3	¿El procedimiento asociado a los mecanismos de autenticación segura para el acceso a la base de datos está formalmente definido, documentado e implementado en la mayor parte de las bases de datos y procesos evaluados?	☐ Sí ☐ No ☐ N/A	
4	¿Se supervisa periódicamente el cumplimiento de lo relacionado con los mecanismos de autenticación segura para el acceso a la base de datos y existe evidencia documentada (bitácoras, reportes o actas) de dicha supervisión?	☐ Sí ☐ No ☐ N/A	
5	¿Se mide el desempeño de los mecanismos de autenticación segura para el acceso a la base de datos mediante indicadores, se evalúa de forma continua y forma parte de un proceso formal de mejora continua?	☐ Sí ☐ No ☐ N/A	

8.8 — Gestión de vulnerabilidades técnicas

Dominio: Tecnológico | Peso: 4/5 | Relación C/I/D: Alta / Alta / Media

Nivel	Pregunta	Respuesta	Evidencia / observaciones
1	¿Existe alguna práctica, aunque sea informal u ocasional, relacionada con la gestión de vulnerabilidades técnicas y parches del motor de base de datos?	☐ Sí ☐ No ☐ N/A	
2	¿Existen lineamientos o procedimientos documentados sobre la gestión de vulnerabilidades técnicas y parches del motor de base de datos, aunque no se apliquen de manera consistente en todos los casos?	☐ Sí ☐ No ☐ N/A	
3	¿El procedimiento asociado a la gestión de vulnerabilidades técnicas y parches del motor de base de datos está formalmente definido, documentado e implementado en la mayor parte de las bases de datos y procesos evaluados?	☐ Sí ☐ No ☐ N/A	
4	¿Se supervisa periódicamente el cumplimiento de lo relacionado con la gestión de vulnerabilidades técnicas y parches del motor de base de datos y existe evidencia documentada (bitácoras, reportes o actas) de dicha supervisión?	☐ Sí ☐ No ☐ N/A	
5	¿Se mide el desempeño de la gestión de vulnerabilidades técnicas y parches del motor de base de datos mediante indicadores, se evalúa de forma continua y forma parte de un proceso formal de mejora continua?	☐ Sí ☐ No ☐ N/A	

8.9 — Gestión de la configuración

Dominio: Tecnológico | Peso: 4/5 | Relación C/I/D: Media / Alta / Media

Nivel	Pregunta	Respuesta	Evidencia / observaciones
1	¿Existe alguna práctica, aunque sea informal u ocasional, relacionada con la gestión segura de la configuración del motor de base de datos?	☐ Sí ☐ No ☐ N/A	
2	¿Existen lineamientos o procedimientos documentados sobre la gestión segura de la configuración del motor de base de datos, aunque no se apliquen de manera consistente en todos los casos?	☐ Sí ☐ No ☐ N/A	
3	¿El procedimiento asociado a la gestión segura de la configuración del motor de base de datos está formalmente definido, documentado e implementado en la mayor parte de las bases de datos y procesos evaluados?	☐ Sí ☐ No ☐ N/A	
4	¿Se supervisa periódicamente el cumplimiento de lo relacionado con la gestión segura de la configuración del motor de base de datos y existe evidencia documentada (bitácoras, reportes o actas) de dicha supervisión?	☐ Sí ☐ No ☐ N/A	
5	¿Se mide el desempeño de la gestión segura de la configuración del motor de base de datos mediante indicadores, se evalúa de forma continua y forma parte de un proceso formal de mejora continua?	☐ Sí ☐ No ☐ N/A	

8.13 — Copias de seguridad de la información

Dominio: Tecnológico | Peso: 5/5 | Relación C/I/D: Baja / Media / Alta

Nivel	Pregunta	Respuesta	Evidencia / observaciones
1	¿Existe alguna práctica, aunque sea informal u ocasional, relacionada con las copias de respaldo de la base de datos?	☐ Sí ☐ No ☐ N/A	
2	¿Existen lineamientos o procedimientos documentados sobre las copias de respaldo de la base de datos, aunque no se apliquen de manera consistente en todos los casos?	☐ Sí ☐ No ☐ N/A	
3	¿El procedimiento asociado a las copias de respaldo de la base de datos está formalmente definido, documentado e implementado en la mayor parte de las bases de datos y procesos evaluados?	☐ Sí ☐ No ☐ N/A	
4	¿Se supervisa periódicamente el cumplimiento de lo relacionado con las copias de respaldo de la base de datos y existe evidencia documentada (bitácoras, reportes o actas) de dicha supervisión?	☐ Sí ☐ No ☐ N/A	
5	¿Se mide el desempeño de las copias de respaldo de la base de datos mediante indicadores, se evalúa de forma continua y forma parte de un proceso formal de mejora continua?	☐ Sí ☐ No ☐ N/A	

8.15 — Registro (logging)

Dominio: Tecnológico | Peso: 4/5 | Relación C/I/D: Media / Alta / Media

Nivel	Pregunta	Respuesta	Evidencia / observaciones
1	¿Existe alguna práctica, aunque sea informal u ocasional, relacionada con la generación de registros (logging) de la actividad de la base de datos?	☐ Sí ☐ No ☐ N/A	

Nivel	Pregunta	Respuesta	Evidencia / observaciones
2	¿Existen lineamientos o procedimientos documentados sobre la generación de registros (logging) de la actividad de la base de datos, aunque no se apliquen de manera consistente en todos los casos?	☐ Sí ☐ No ☐ N/A	
3	¿El procedimiento asociado a la generación de registros (logging) de la actividad de la base de datos está formalmente definido, documentado e implementado en la mayor parte de las bases de datos y procesos evaluados?	☐ Sí ☐ No ☐ N/A	
4	¿Se supervisa periódicamente el cumplimiento de lo relacionado con la generación de registros (logging) de la actividad de la base de datos y existe evidencia documentada (bitácoras, reportes o actas) de dicha supervisión?	☐ Sí ☐ No ☐ N/A	
5	¿Se mide el desempeño de la generación de registros (logging) de la actividad de la base de datos mediante indicadores, se evalúa de forma continua y forma parte de un proceso formal de mejora continua?	☐ Sí ☐ No ☐ N/A	

8.16 — Actividades de monitoreo

Dominio: Tecnológico | Peso: 4/5 | Relación C/I/D: Media / Alta / Alta

Nivel	Pregunta	Respuesta	Evidencia / observaciones
1	¿Existe alguna práctica, aunque sea informal u ocasional, relacionada con las actividades de monitoreo de la actividad y el desempeño de la base de datos?	☐ Sí ☐ No ☐ N/A	
2	¿Existen lineamientos o procedimientos documentados sobre las actividades de monitoreo de la actividad y el desempeño de la base de datos, aunque no se apliquen de manera consistente en todos los casos?	☐ Sí ☐ No ☐ N/A	
3	¿El procedimiento asociado a las actividades de monitoreo de la actividad y el desempeño de la base de datos está formalmente definido, documentado e implementado en la mayor parte de las bases de datos y procesos evaluados?	☐ Sí ☐ No ☐ N/A	
4	¿Se supervisa periódicamente el cumplimiento de lo relacionado con las actividades de monitoreo de la actividad y el desempeño de la base de datos y existe evidencia documentada (bitácoras, reportes o actas) de dicha supervisión?	☐ Sí ☐ No ☐ N/A	
5	¿Se mide el desempeño de las actividades de monitoreo de la actividad y el desempeño de la base de datos mediante indicadores, se evalúa de forma continua y forma parte de un proceso formal de mejora continua?	☐ Sí ☐ No ☐ N/A	

8.24 — Uso de criptografía

Dominio: Tecnológico | Peso: 4/5 | Relación C/I/D: Alta / Media / Baja

Nivel	Pregunta	Respuesta	Evidencia / observaciones
1	¿Existe alguna práctica, aunque sea informal u ocasional, relacionada con la aplicación de cifrado sobre los datos almacenados y transmitidos por la base de datos?	☐ Sí ☐ No ☐ N/A	
2	¿Existen lineamientos o procedimientos documentados sobre la aplicación de cifrado sobre los datos almacenados y transmitidos por la base de datos, aunque no se apliquen de manera consistente en todos los casos?	☐ Sí ☐ No ☐ N/A	
3	¿El procedimiento asociado a la aplicación de cifrado sobre los datos almacenados y transmitidos por la base de datos está formalmente definido, documentado e implementado en la mayor parte de las bases de datos y procesos evaluados?	☐ Sí ☐ No ☐ N/A	
4	¿Se supervisa periódicamente el cumplimiento de lo relacionado con la aplicación de cifrado sobre los datos almacenados y transmitidos por la base de datos y existe evidencia documentada (bitácoras, reportes o actas) de dicha supervisión?	☐ Sí ☐ No ☐ N/A	
5	¿Se mide el desempeño de la aplicación de cifrado sobre los datos almacenados y transmitidos por la base de datos mediante indicadores, se evalúa de forma continua y forma parte de un proceso formal de mejora continua?	☐ Sí ☐ No ☐ N/A	

8.32 — Gestión de cambios

Dominio: Tecnológico | Peso: 3/5 | Relación C/I/D: Media / Alta / Media

Nivel	Pregunta	Respuesta	Evidencia / observaciones
1	¿Existe alguna práctica, aunque sea informal u ocasional, relacionada con la gestión de cambios sobre el esquema, la configuración y los objetos de la base de datos?	☐ Sí ☐ No ☐ N/A	
2	¿Existen lineamientos o procedimientos documentados sobre la gestión de cambios sobre el esquema, la configuración y los objetos de la base de datos, aunque no se apliquen de manera consistente en todos los casos?	☐ Sí ☐ No ☐ N/A	
3	¿El procedimiento asociado a la gestión de cambios sobre el esquema, la configuración y los objetos de la base de datos está formalmente definido, documentado e implementado en la mayor parte de las bases de datos y procesos evaluados?	☐ Sí ☐ No ☐ N/A	
4	¿Se supervisa periódicamente el cumplimiento de lo relacionado con la gestión de cambios sobre el esquema, la configuración y los objetos de la base de datos y existe evidencia documentada (bitácoras, reportes o actas) de dicha supervisión?	☐ Sí ☐ No ☐ N/A	
5	¿Se mide el desempeño de la gestión de cambios sobre el esquema, la configuración y los objetos de la base de datos mediante indicadores, se evalúa de forma continua y forma parte de un proceso formal de mejora continua?	☐ Sí ☐ No ☐ N/A	

4. Metodología para el Cálculo del Nivel de Madurez

4.1 Regla de determinación del nivel de madurez por control

El nivel de madurez de un control sale de forma automática a partir de las respuestas a sus cinco preguntas escalonadas, aplicando esta regla acumulativa: el nivel de madurez es igual al mayor nivel k (entre 1 y 5) tal que todas las preguntas de nivel 1 hasta k se respondieron Sí, tomando las respuestas No aplica como que no rompen la cadena, pero que tampoco cuentan como evidencia positiva por sí solas. Si la pregunta de nivel 1 se responde No, el control queda en nivel 0. Y si la pregunta de nivel 1 se responde No aplica, el control completo se excluye de los cálculos, como ya se explicó en la sección 3.2.

Esta regla sale directamente de cómo está pensada la escala del proyecto: un control no puede estar en nivel 4 ("completamente implementado, supervisado y con evidencia") si ni siquiera llegó al nivel 3 ("documentado e implementado"). Por eso no se usa un promedio simple de las cinco respuestas: con un promedio, un control podría sacar un nivel alto solo por acumular varios "Sí" sueltos, sin cumplir de verdad con las condiciones de los niveles anteriores.

Ejemplo de aplicación de la regla

Supongamos que, durante la auditoría del control 8.2 (Derechos de acceso privilegiado), se obtuvieron estas respuestas:

Nivel	Pregunta	Respuesta	Resultado
1	¿Existe práctica informal de gestión de accesos privilegiados?	Sí	Nivel alcanzado ≥ 1
2	¿Existen lineamientos documentados, aunque inconsistentes?	Sí	Nivel alcanzado ≥ 2
3	¿Está formalmente definido e implementado en la mayoría de las BD?	Sí	Nivel alcanzado ≥ 3
4	¿Se supervisa periódicamente con evidencia documentada?	No	La cadena se corta acá
5	¿Se mide, se evalúa continuamente y forma parte de mejora continua?	No evaluada	Ya no cuenta, la cadena venía cortada

Las preguntas de nivel 1, 2 y 3 se respondieron "Sí", pero la de nivel 4 salió "No", así que la cadena se corta ahí. El nivel de madurez que le queda al control 8.2 en esta auditoría es 3 ("el control está documentado, definido e implementado en la mayor parte de los procesos"), sin importar lo que se hubiera respondido en la pregunta de nivel 5, porque esa ya no se evalúa una vez que la cadena se interrumpe.

4.2 Nivel de cumplimiento del control

Con el nivel de madurez ya calculado, el cumplimiento porcentual de cada control se saca así:

$$\text{Cumplimiento del control (\%)} = (\text{Nivel de madurez del control} / 5) \times 100$$

En el ejemplo anterior, el control 8.2 quedaría con $(3/5) \times 100 = 60\%$ de cumplimiento. Este es el número que se usa para los reportes de "nivel de cumplimiento de cada control" y "nivel de cumplimiento por dominio" que pide el alcance funcional del sistema.

4.3 Nivel de cumplimiento por dominio y nivel de cumplimiento general

El nivel de cumplimiento de un dominio (organizacional, personas, físico o tecnológico) se calcula como el promedio del cumplimiento de sus controles, ponderado por el peso de cada uno y excluyendo los controles marcados como No aplica en esa auditoría:

$$\text{Cumplimiento del dominio (\%)} = \Sigma (\text{peso}_i \times \text{cumplimiento}_i) / \Sigma (\text{peso}_i), \text{ para los controles } i \text{ del dominio}$$

El nivel de cumplimiento general de la auditoría se calcula con la misma fórmula, pero considerando los 20 controles aplicables en vez de solo los de un dominio. Se pondera por el peso del control, en lugar de promediar de forma simple, para que un control de bajo impacto (por ejemplo, peso 2) no pese igual que un control crítico (peso 5), lo cual sería inconsistente con la justificación de pesos ya presentada en la primera parte del trabajo.

5. Metodología para el Cálculo de la Exposición al Riesgo

5.1 Fundamento conceptual

La metodología parte de una idea central de la gestión del riesgo: entre más ausentes o débiles estén los controles que deberían proteger un activo, más expuesto queda ese activo. Por eso se define la brecha de un control como lo que le falta para llegar al máximo de la escala:

$$\text{Brecha del control} = (5 - \text{Nivel de madurez del control}) / 5$$

La brecha vale 0 cuando el control llega al nivel máximo de madurez (5, sin exposición atribuible a ese control) y vale 1 cuando el control no existe (nivel 0, la máxima exposición posible atribuible a ese control). Esta brecha se combina con el peso del control y con su relación específica con C, I y D, de modo que el riesgo no se reparte por igual entre las tres dimensiones, sino en proporción a la incidencia real de cada control sobre cada una, tal como se definió en la primera parte del trabajo.

5.2 Coeficientes de incidencia sobre C, I y D

La relación cualitativa (Alta / Media / Baja) que se le asignó a cada control respecto a C, I y D en la primera parte del trabajo se convierte en un número para poder usarla en las fórmulas:

- Alta = 1.0
- Media = 0.6
- Baja = 0.3

No se usó una escala pareja (0, 0.5, 1.0) porque se quería que la categoría "Alta" pesara claramente más que "Media" y "Baja", reflejando que un control con incidencia alta sobre una propiedad debe dominar el índice de esa dimensión, y no simplemente valer el doble que uno con incidencia baja.

5.3 Fórmula de riesgo por control y por dimensión

El aporte de riesgo de un control i a la dimensión X (siendo $X = C, I$ o D) se calcula así:

$$\text{Riesgo}(i, X) = \text{Peso}_i \times \text{CoefCID}_{i,X} \times \text{Brecha}_i$$

La exposición al riesgo de la dimensión X , ya a nivel de toda la auditoría, se obtiene normalizando la suma de estos aportes contra el máximo riesgo posible en esa dimensión (el que se daría si todos los controles relevantes tuvieran madurez 0):

$$\text{Exposición al riesgo de } X (\%) = \left[\sum \text{Riesgo}(i, X) / \sum (\text{Peso}_i \times \text{CoefCID}_{i,X}) \right] \times 100, \text{ para los controles } i \text{ con relación CID definida en } X$$

Esta normalización asegura que el resultado sea siempre un porcentaje entre 0% y 100%, que se puede comparar entre auditorías y entre organizaciones distintas, sin importar cuántos controles se evaluaron ni cómo se distribuyeron sus pesos.

5.4 Índice general de exposición al riesgo

El índice general de riesgo se calcula como el promedio simple de las tres exposiciones por dimensión:

$$\text{Índice general de riesgo } (\%) = (\text{Exposición C} + \text{Exposición I} + \text{Exposición D}) / 3$$

Se optó por un promedio simple, sin ponderar de antemano una dimensión sobre otra, porque la ISO/IEC 27002 no establece que una de las tres deba pesar siempre más que las otras; eso depende del contexto de cada

organización (una entidad financiera puede priorizar la integridad, mientras que un proveedor de servicios en línea puede priorizar la disponibilidad). Como funcionalidad de valor agregado, se plantea la posibilidad de permitir configurar pesos distintos entre C, I y D a nivel de organización, dejando el promedio simple como valor por defecto (ver sección 6).

5.5 Escala de interpretación del riesgo

Tanto la exposición por dimensión como el índice general se interpretan con esta misma escala:

Rango (%)	Nivel	Interpretación
0% – 25%	Bajo	La exposición es baja. Los controles relacionados están mayoritariamente implementados y con un nivel de madurez adecuado.
26% – 50%	Medio	Hay una exposición moderada. Conviene priorizar la mejora de los controles con mayor brecha dentro del dominio o dimensión evaluada.
51% – 75%	Alto	La exposición es alta. Hace falta un plan de tratamiento del riesgo a corto plazo sobre los controles críticos identificados.
76% – 100%	Crítico	La exposición es crítica. Se requiere acción inmediata; hay una probabilidad considerable de que se materialice un incidente sobre la propiedad evaluada.

5.6 Ejemplo numérico completo

Se ilustra la metodología con un subconjunto de 5 controles y valores de madurez hipotéticos obtenidos en una auditoría:

Código	Control	Peso	Madurez	Brecha	CoefC	CoefI	CoefD
5.15	Control de acceso	5	2	0.6	1.0	1.0	0.6
8.2	Acceso privilegiado	5	1	0.8	1.0	1.0	1.0
8.13	Copias de seguridad	5	4	0.2	0.3	0.6	1.0
8.24	Uso de criptografía	4	0	1.0	1.0	0.6	0.3
6.3	Capacitación	2	3	0.4	0.6	0.6	0.3

Aplicando las fórmulas de las secciones 5.3 y 5.4 sobre estos 5 controles se obtiene:

Dimensión	Fórmula aplicada	Resultado
Exposición C	$\Sigma(\text{peso} \times \text{coefC} \times \text{brecha}) / \Sigma(\text{peso} \times \text{coefC}) = 11.78 / 16.70$	70.5% → Alto
Exposición I	$\Sigma(\text{peso} \times \text{coefI} \times \text{brecha}) / \Sigma(\text{peso} \times \text{coefI}) = 10.48 / 16.60$	63.1% → Alto
Exposición D	$\Sigma(\text{peso} \times \text{coefD} \times \text{brecha}) / \Sigma(\text{peso} \times \text{coefD}) = 8.24 / 14.80$	55.7% → Alto
Índice general	$(\text{Exposición C} + \text{Exposición I} + \text{Exposición D}) / 3$	63.1% → Alto
Cumplimiento general (referencia)	$\Sigma(\text{peso} \times \text{cumplimiento}_i) / \Sigma(\text{peso})$	39.0%

El ejemplo deja ver algo importante de la metodología: el índice de riesgo (63.1%) y el cumplimiento ponderado (39.0%) no son estrictamente complementarios ($100\% - 39.0\% \neq 63.1\%$). Esto es intencional: el cumplimiento pondera solo por el peso del control, mientras que el riesgo además pondera por la incidencia específica de cada

control sobre cada dimensión CID; dos controles con la misma madurez pero distinta relación con C, I y D aportan distinto al riesgo aunque aporten igual al cumplimiento. Esta distinción hay que conservarla en los reportes finales, sin presentar el riesgo como un simple "100% menos el cumplimiento".

6. Indicadores, Gráficos y Mapas de Calor Requeridos

Esta sección deja definidos los indicadores visuales que la aplicación debe generar a partir de los cálculos de las secciones 4 y 5, junto con los datos mínimos que necesita cada uno.

6.1 Panel ejecutivo (resumen de auditoría)

- Índice general de exposición al riesgo (valor porcentual + semáforo Bajo/Medio/Alto/Crítico según la escala de la sección 5.5).
- Nivel de cumplimiento general (%) de la auditoría.
- Cantidad de controles evaluados, cantidad de controles marcados como No aplica y cantidad de preguntas respondidas.

6.2 Gráficos de barras

- Nivel de cumplimiento por dominio (4 barras: Organizacional, Personas, Físico, Tecnológico).
- Nivel de madurez por control (20 barras, ordenadas de menor a mayor madurez), para identificar de un vistazo los controles más débiles.

6.3 Gráfico radar o de barras comparativo

- Exposición al riesgo de Confidencialidad, Integridad y Disponibilidad, mostradas al mismo tiempo para ver si el riesgo está concentrado en una dimensión en particular.

6.4 Mapas de calor

- Mapa de calor de controles × nivel de madurez: una celda por control coloreada según su nivel (0 = rojo intenso, 5 = verde intenso), agrupado por dominio.
- Mapa de calor de riesgo (matriz peso × brecha): eje horizontal = brecha de madurez (0 a 1), eje vertical = peso del control (1 a 5), cada control ubicado como un punto o celda coloreada según su nivel de riesgo resultante; permite ver de forma visual los controles de "alto peso + alta brecha" que necesitan atención prioritaria.

6.5 Rankings

- Top 5 controles con menor nivel de madurez (código, nombre, dominio, nivel de madurez, peso).
- Top 5 controles con mayor exposición al riesgo individual (Riesgo(i, X) más alto, indicando en qué dimensión C/I/D se concentra).

6.6 Otros indicadores

- Gráfico circular con la distribución global de respuestas Sí / No / N-A de la auditoría.
- Indicadores estadísticos: promedio, mínimo y máximo del nivel de madurez; porcentaje de controles en cada banda de riesgo (Bajo/Medio/Alto/Crítico).
- Gráfico de líneas con la evolución del índice general de riesgo y del cumplimiento general entre auditorías sucesivas de una misma organización, para dar seguimiento histórico.
- Reporte ejecutivo exportable en PDF que junte el panel ejecutivo, los gráficos de dominio y los dos rankings de la sección 6.5.

Para construir estos indicadores, la base de datos debe guardar, por cada control y por cada auditoría: el nivel de madurez calculado, el cumplimiento porcentual, el estado de cada una de las 5 preguntas (Sí/No/N-A) y el riesgo aportado a cada dimensión C, I y D; estos son los campos mínimos que se deben contemplar en el modelo de datos para no tener que recalcular la lógica de negocio desde la capa de reportes.

7. Cierre

Con el cuestionario completo de 100 preguntas (sección 3.3), las fórmulas exactas de madurez y riesgo (secciones 4 y 5) y la lista de indicadores y campos requeridos (sección 6), queda la base para diseñar el modelo entidad-relación, las tablas de respuestas y resultados, y las pantallas de captura y de reportes de la aplicación web. Se recomienda que la aplicación guarde tanto las respuestas crudas (Sí/No/N-A por pregunta) como los resultados ya calculados (madurez, cumplimiento y riesgo por control), para que los cálculos se puedan auditar y no dependan de recalcularse en cada consulta.